

Security+ 2.2 · Impersonation

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 2.2** — Impersonation (5:52) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Impersonation involves identity theft during a conversation or physical interaction. Key forms: Business Email Compromise (BEC) — attacker impersonates an executive to trick internal victims; tailgating — following an authorized person through a secure door; shoulder surfing — observing someone's screen or keypad; dumpster diving — retrieving sensitive information from trash; brand impersonation — posing as a trusted brand or support entity.

High-Yield Core Concepts Tested on Exam

- BEC: the email IMPERSONATES an executive (target is internal victim)
- Whaling: the email TARGETS the executive (spear phishing of exec) — distinct from BEC
- Tailgating: entering a door behind someone with legitimate access
- Shoulder surfing: visually stealing credentials or data over someone's shoulder
- Dumpster diving: recovering sensitive data from discarded materials

Exam Tips & Classic Scenarios

- 'sender claims to be an executive' = BEC
- 'follows an authorized person through a door' = tailgating/piggybacking
- 'looking over someone's shoulder' = shoulder surfing
- 'searching trash for information' = dumpster diving

Typical Exam Scenario: Scenario: 'attacker sends an email claiming to be the CEO and requests an urgent transfer' = BEC — not whaling (whaling TARGETS the CEO; BEC IMPERSONATES the CEO).

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 2.2 — Impersonation)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. A scammer sends an email IMPERSONATING the CEO and orders the finance department to make an urgent transfer. What attack is this?

- A)** BEC / CEO fraud
- B)** Whaling
- C)** Vishing
- D)** Tailgating

2. An employee receives a call from someone pretending to be technical support asking for a password for a 'system update'. What technique is this?

- A) Vishing**
- B) Pretexting**
- C) Baiting**
- D) Tailgating**

3. A scammer calls pretending to be IT support and creates urgency for you to give your password. The social engineering principle exploited is:

- A) Scarcity**
- B) Authority + urgency**
- C) Social proof**
- D) Reciprocity**

4. An attacker uses RFID to clone employee badges and access restricted areas. What type of physical attack is this?

- A) Tailgating**
- B) Shoulder surfing**
- C) Credential cloning**
- D) Dumpster diving**

5. Corporate scenario (Impersonation): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.2), an analyst evaluates the following technical requirement: 'BEC: the email IMPERSONATES the executive (internal victim)'. What is the best recommendation or applicable control classification?

- A) Temporarily disable audit logs to accelerate system throughput**
- B) Replace preventive technical controls with informal terms of adherence**
- C) Allow shared access among administrators with generic credentials**
- D) Implement the corresponding solution: BEC: the email IMPERSONATES the executive (internal victim)...**

6. Corporate scenario (Impersonation): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.2), an analyst evaluates the following technical requirement: 'Whaling: the email TARGETS the executive (exec spear phishing) — different from BEC'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Whaling: the email TARGETS the executive (exec spear phishing) — different from BEC...
- D)** Allow shared access among administrators using generic credentials

7. Corporate scenario (Impersonation): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.2), an analyst evaluates the following technical requirement: 'Tailgating: enters the door behind someone who has access.' What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Tailgating: enters the door behind someone who has access...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

8. Corporate scenario (Impersonation): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.2), an analyst evaluates the following technical requirement: 'sender claims to be an executive' = BEC'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'sender claims to be an executive' = BEC...
- D)** Allow shared access among administrators using generic credentials

9. Corporate scenario (Impersonation): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.2), an analyst evaluates the following technical requirement: "follows an authorized person through a door" = tailgating/piggybacking'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'follows an authorized person through a door' = tailgating/piggybacking...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

10. Corporate scenario (Impersonation): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.2), an analyst evaluates the following technical requirement: 'Scenario: 'attacker sends email claiming to be the CEO and requests an urgent transfer' = BEC — not whaling (whaling TARGETS the CEO; BEC IMPERSONATES them)'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Scenario: 'attacker sends email claiming to be the CEO and requests an urgent transfer...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) A — BEC / CEO fraud.

✓ **Why it is correct:** The correct answer is 'BEC / CEO fraud'. Business Email Compromise (BEC) is a category of social engineering attack where the attacker impersonates a high-level executive (such as the CEO) or a trusted business partner to induce employees to make unauthorized financial transfers or disclose confidential information. In the described scenario, the scammer sends a fraudulent email impersonating the CEO and orders an urgent transfer to the finance department. This perfectly fits the definition of BEC, which CompTIA recognizes as an attack vector based on impersonation and social engineering. The specific variant where the CEO is impersonated is called CEO fraud. Therefore, the option 'BEC / CEO fraud' best describes the attack.

✗ **Why the others are wrong:**

- *Whaling:* Whaling is a type of phishing attack specifically targeting high-level executives (such as CEOs, CFOs, etc.). The goal is to obtain confidential information or access to critical systems through fraudulent emails impersonating trusted sources. However, in the described scenario, the attacker is not targeting the CEO but impersonating them to deceive the finance department. Therefore, whaling is not the correct term, as it describes the target (the executive) and not the modus operandi of impersonating the CEO to defraud subordinates.
- *Vishing:* Vishing is the practice of social engineering conducted via phone calls (voice phishing), where the attacker impersonates a trusted entity to obtain sensitive information, such as passwords or financial data. In the scenario, the attack occurs via email, not phone. Therefore, vishing does not apply to the channel used. Additionally, vishing does not necessarily involve impersonating the CEO to order transfers, but rather fraudulent calls in general.
- *Tailgating:* Tailgating is a physical unauthorized access technique where a person follows another into a restricted area without authenticating, usually exploiting the courtesy or distraction of an authorized employee. It is unrelated to email social engineering attacks or financial fraud. The scenario describes a cyber attack based on fraudulent email, not a physical intrusion. Therefore, tailgating is completely inadequate for the situation.

2) A — Vishing.

✓ **Why it's correct:** The correct answer is 'Vishing'. Vishing is a combination of 'voice' and 'phishing', i.e., social engineering conducted via telephone calls (VoIP or traditional telephone network). In the described scenario, the attacker impersonates technical support to obtain the victim's password, exactly characterizing a vishing attack. CompTIA Security+ classifies vishing as a voice-based social engineering attack, where real-time interaction increases psychological pressure and perceived credibility. The goal is to induce the victim to reveal credentials or perform harmful actions.

✗ **Why the others are wrong:**

- *Pretexting:* Pretexting is the creation of a false scenario or pretext to obtain information. Although the attacker in the statement uses a pretext (fake technical support), the primary vector is the telephone. Pretexting is a common element in many social engineering attacks, including vishing, phishing, and smishing. The alternative is incorrect because it does not specify the telephone channel, which is the defining characteristic of vishing. Technically, pretexting is the technique of building the story, while vishing is the delivery method via voice.
- *Baiting:* Baiting involves leaving a physical device (such as an infected USB drive) or a digital lure for the victim to use, exploiting curiosity. There is no relation to telephone calls or direct password requests by voice. The alternative is incorrect because it describes an attack that depends on

physical action or interaction with removable media, not real-time verbal interaction.

- *Tailgating*: Tailgating is a physical unauthorized access technique where the attacker follows an authorized employee through a secure door without authenticating. It does not involve telephone, verbal social engineering, or obtaining a password. The alternative is incorrect because it belongs to the category of physical attacks, while the scenario describes a remote voice social engineering attack.

3) B — Authority + urgency.

✓ **Why it's correct:** The correct alternative is 'Authority + urgency'. Social engineering exploits cognitive biases and psychological principles to manipulate victims. In the scenario, the scammer impersonates IT support, which invokes the principle of authority (the victim tends to obey authority figures). Additionally, he creates a sense of urgency to pressure the victim to act quickly, without thinking critically. The combination of authority and urgency is a classic social engineering tactic, recognized by CompTIA. Therefore, the option 'Authority + urgency' accurately describes the principles exploited.

✗ **Why the others are wrong:**

- *Scarcity*: Scarcity is a persuasion principle that exploits the perception that resources are limited, creating a feeling that the opportunity may be lost if not acted upon immediately. In the scenario, there is no mention of scarce resources or limited offers. The scammer is not offering something in limited quantity, but rather impersonating authority and creating urgency. Therefore, scarcity is not the applicable principle.
- *Social proof*: Social proof is the tendency for people to follow the behavior of others, assuming that actions taken by many are correct. In the described attack, there is no mention of other people doing the same or endorsing the action. The scammer does not use the idea that 'everyone is doing it' to convince the victim. Therefore, social proof is not the principle exploited.
- *Reciprocity*: Reciprocity is the principle that people feel obliged to return a favor or concession. In the scenario, the scammer does not offer anything first and then ask for the password; he simply impersonates support and creates urgency. There is no exchange of favors. Therefore, reciprocity does not apply.

4) C — Credential cloning.

✓ **Why it's correct:** The correct answer is 'Credential cloning'. Credential cloning occurs when an attacker copies the data from an access card (such as RFID badges or proximity cards) to another device, allowing unauthorized access. In the scenario, using RFID to copy the badge signal and replicate it onto a blank card is a classic example of physical credential cloning. CompTIA Security+ covers physical attacks and countermeasures, such as using encrypted cards or mutual authentication to prevent cloning.

✗ **Why the others are wrong:**

- *Tailgating*: Tailgating is the practice of physically following an authorized person through a secure door without using one's own credentials. It does not involve cloning cards or RFID; it is a passive physical intrusion. The option is incorrect because the scenario describes electronic copying of credentials, not entry by proximity.
- *Shoulder surfing*: Shoulder surfing is direct observation over someone's shoulder to obtain information such as passwords or PINs. It does not involve RFID or badge cloning. The option is incorrect because it is a visual observation technique, not electronic duplication.
- *Dumpster diving*: Dumpster diving is searching through trash for discarded information (documents, media) that could be useful to an attacker. It has no relation to RFID or credential cloning. The option is incorrect because it involves recovering discarded data, not intercepting and copying card signals.

5) D — Implement the corresponding solution: BEC: the email IMPERSONATES the executive (internal victim)....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.2 (Impersonation): BEC: the email IMPERSONATES the executive (internal victim). Business Email Compromise (BEC) is a form of impersonation where an attacker spoofs or compromises an executive's email account to trick employees into transferring funds or revealing sensitive information. The correct control includes email authentication (SPF, DKIM, DMARC), user awareness training, and verification procedures for financial transactions.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

6) C — Implement the corresponding solution: Whaling: the email TARGETS the executive (exec spear phishing) — different from BEC....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.2 (Impersonation): Whaling: the email TARGETS the executive (exec spear phishing) — different from BEC.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) A — Implement the corresponding solution: Tailgating: enters the door behind someone who has access....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.2 (Impersonation): Tailgating: enters the door behind someone who has access. This is a physical social engineering technique where an unauthorized person follows an authorized individual into a restricted area.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.

- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

8) C — Implement the corresponding solution: 'sender claims to be an executive' = BEC....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.2 (Impersonation): 'sender claims to be an executive' = BEC (Business Email Compromise). BEC is a form of impersonation where an attacker spoofs or compromises an executive's email account to trick employees into transferring funds or revealing sensitive information.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) B — Implement the corresponding solution: 'follows an authorized person through a door' = tailgating/piggybacking....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.2 (Impersonation): 'follows an authorized person through a door' = tailgating/piggybacking.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

10) B — Implement the corresponding solution: Scenario: 'attacker sends email claiming to be the CEO and requests an urgent transfer....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.2 (Impersonation): Scenario: 'attacker sends email claiming to be the CEO and requests an urgent transfer' = BEC — not whaling (whaling TARGETS the CEO; BEC IMPERSONATES them). Business Email Compromise (BEC) involves an attacker impersonating a high-level executive to trick employees into transferring funds or revealing sensitive information. Whaling, by contrast, specifically targets the CEO or other senior executives as the victim. The correct classification is BEC.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates

compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.